

Remediation Meta

Per l'analisi completa delle vulnerabilità si rimanda al file [scansione iniziale meta.pdf](#).

A seguito della scansione eseguita sulla macchina meta del nostro laboratorio emergono delle vulnerabilità classificate come **CRITICAL** e **HIGH** di cui ci occuperemo.

Usiamo nmap -sV per validare i risultati dati da nessus, -sV è l'opzione che ci permette di verificare la versione di un servizio attivo e ci da informazioni circa le porte aperte su un sistema.

```
(kali@vbox)-[~]
$ nmap -sV 192.168.1.28
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-20 19:39 CEST
Stats: 0:00:52 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 19:40 (0:00:02 remaining)
Stats: 0:01:02 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 19:40 (0:00:03 remaining)
Stats: 0:01:02 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 19:40 (0:00:03 remaining)
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 19:40 (0:00:03 remaining)
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 84.00% done; ETC: 19:40 (0:00:00 remaining)
Nmap scan report for 192.168.1.28
Host is up (0.017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:D9:D3:3E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 64.81 seconds
```

La Bind Shell Backdoor Detection, presente anche nella consegna dell'esercizio è la criticità con la porta 1524/tcp che ritroviamo anche nella scansione con nmap e che porta il nome di Metasploitable root shell.

Confermiamo sia aperta con netcat.

```
(kali@vbox)-[~]  
$ nc 192.168.1.28 1524  
root@metasploitable:/# ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000  
    link/ether 08:00:27:d9:d3:3e brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.28/24 brd 192.168.1.255 scope global eth0  
    inet6 fe80::a00:27ff:fed9:d33e/64 scope link  
        valid_lft forever preferred_lft forever  
root@metasploitable:/# whoami  
root  
root@metasploitable:/#
```

Ip e root whoami corrispondono alla macchina target.

Filtriamo la porta con `sudo iptables -A INPUT -p tcp --dport 1524 -j DROP` e chiudiamo così la backdoor, la prova con la macchina kali ci da ragione.

```
(kali@vbox)-[~]  
$ nc 192.168.1.28 1524  
(UNKNOWN) [192.168.1.28] 1524 (ingreslock) : Connection timed out
```

Segue VNC Server 'password' Password, un server VNC (Virtual Network Computing) attivo su meta alla porta tcp 5900 ha una password debole, la banale ma sempre efficace soluzione è quella di sostituire la password debole con una più forte e articolata di modo che un attaccante non possa individuarla facilmente. Se non si interviene è possibile per un attaccante prendere possesso della macchina.

Da meta usiamo il comando `sudo vncpasswd` per sostituire la password del VNC da standard e debole a forte, in questo caso abbiamo usato `pippo79`.

Come si evince dalla immagine sotto usando vncviewer con la password standard non è possibile loggarsi. Si deve quindi conoscere ora la password per poter entrare.

```
(kali@vbox)-[~]
$ vncviewer 192.168.1.28:5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure
```

Per il risultato visualizzare il pdf di scansione finale.

Viene di seguito riportata la nuova scansione con nmap.

```
(kali@vbox)-[~]
$ nmap -sV 192.168.1.28
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-20 20:52 CEST
Nmap scan report for 192.168.1.28
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  filtered ingreslock
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:D9:D3:3E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.33 seconds
```

Possiamo vedere come la 1524 sia ora filtrata, la 5900 risulta aperta ma ora un attaccante non può più connettersi usando la password standard.

